PES UNIVERSITY

LAB 3: Component Modelling & Architectural Pattern Selection – Written Justification

Name: Satwik S Inchageri

SRN: PES1UG24CS618

Section: K

Scenario 13: Patient Health Record Consent Management System

Architecture Selection

We choose layered architecture for the patient health record consent management system.

Architectural Choice

A three-layered Architecture in which each layer depends only on the layer directly below it. Presentation Layer: Patient Portal UI, Clinic & Doctor Portal UI. Business Layer: Consent Manager, Doctor Verification Service, Access Control Service, Audit Trail Service, Notification Service. Data Layer: Consent & Records Database. Components talk only through the provided/required interfaces in the diagram (ConsentManagement, RecordAccess, ConsentValidation, DoctorVerification, AuditLog, Notification, DataAccess).

Two Reasons

1. Consent rules must be enforced in exactly one place. FR-001 to FR-004 are business rules: time-bound grants, immediate revocation, access only under a valid consent, and verified doctors only. The Business Layer keeps these rules out of the portals and the database, so a request from a patient or from a doctor always passes through the same Consent Manager and Access Control checks, and a change such as a new expiry option touches one layer only.

2. The system is a cohesive, consent-critical application with a clear top-down flow. Every use case (UC-01 to UC-08) follows Actor -> Portal ->Service ->Database. Revocation must take effect immediately (FR-002) and every event is audited (NFR-001), so strong

consistency matters: a single shared data layer provides it directly. Microservices would add distributed data, eventual-consistency risk (a revoked consent could still be honored) and operational overhead that is unjustified at this scale, while Client-Server gives no internal separation between consent logic, UI and storage.

Security Advantage

Layer boundaries create a single choke point for access control. The portals can call only business interfaces, and only business components hold DataAccess (and the database credentials). Before any record is returned, the Access Control Service calls ConsentValidation (consent active and not expired) and DoctorVerification (doctor verified), denying access by default; this satisfies FR-003 and NFR-002. Every grant, revoke and access event is written through AuditLog to the append-only Audit Service (NFR-001).

Performance Benefit

Business components run in the same tier, so consent validation, doctor verification and audit logging are lightweight in-process calls rather than network hops between separate services, as they would be in Microservices. Expiry is a timestamp comparison on an indexed consent lookup (patient, doctor, record) made at access time, so each record request needs one fast query and expiry or revocation applies instantly without a background job. Layers can also be scaled independently (more business-tier instances, database replicas) as usage grows.

Trade-off: each request crosses layers, adding a small call overhead; we accept it for the clarity, testability and security gained.